

# HobiMart

## Bug Audit Report

Frontend (Next.js/React) + Backend (Laravel/PHP)

| Severity | Count | Action Required        |
|----------|-------|------------------------|
| CRITICAL | 19    | Fix immediately        |
| HIGH     | 42    | Fix before production  |
| MEDIUM   | 41    | Fix in next sprint     |
| LOW      | 22    | Backlog / nice-to-have |
| TOTAL    | 124   |                        |

# 1. Backend (Laravel/PHP) Bugs

The backend analysis covers all Controllers, Models, Middleware, Routes, Services, Migrations, and Configuration files. A total of 65 bugs were identified across 4 severity levels, with 13 Critical and 21 High severity issues requiring immediate attention.

## 1.1 Critical Severity (13 bugs)

| ID    | Severity | Category             | Description                                                                                                                                                                                                                                                                                          |
|-------|----------|----------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BE-01 | CRITICAL | Authorization        | <b>AdminController routes missing admin middleware</b><br>File: routes/api.php:139-141<br>3 admin endpoints (/admin/stats, /admin/verify-seller, /admin/verify-product) are inside auth:sanctum but OUTSIDE the admin middleware group. Any authenticated user can access admin-only endpoints.      |
| BE-02 | CRITICAL | IDOR                 | <b>ProductController update/destroy: no ownership check</b><br>File: ProductController.php:255-290<br>update() and destroy() find a product by SKU but never verify product->seller_id === user()->id. Any authenticated user can edit or delete any product.                                        |
| BE-03 | CRITICAL | IDOR                 | <b>OrderController show/pay: no ownership check</b><br>File: OrderController.php:170-244<br>show() and pay() find orders by order_number without verifying order->user_id === user()->id. Any authenticated user can view or pay for any order.                                                      |
| BE-04 | CRITICAL | IDOR                 | <b>ShippingController: no auth or ownership check</b><br>File: ShippingController.php:11-43<br>generateLabel() has no authentication and no ownership verification. Anyone can generate shipping labels for any order and modify order status/timeline.                                              |
| BE-05 | CRITICAL | IDOR                 | <b>TradeInController accept/reject: no seller auth</b><br>File: TradeInController.php:126-170<br>accept() and reject() don't verify the authenticated user is the seller. Any user can accept/reject any trade-in request.                                                                           |
| BE-06 | CRITICAL | Security/Logic       | <b>ProductController store: fallback seller_id to first user</b><br>File: ProductController.php:225<br>If no user is authenticated and no seller_id provided, it falls back to the first user in the database, assigning products to an arbitrary user. seller_id from request also allows spoofing. |
| BE-07 | CRITICAL | Logic/Data Integrity | <b>Order creation: no stock check or decrement</b><br>File: OrderController.php:40-59<br>When creating an order, there's no verification that product->stock >= quantity, and no stock decrement after purchase. Products can be oversold with negative stock.                                       |
| BE-08 | CRITICAL | Model Bug            | <b>Order items relationship/cast naming collision</b><br>File: Order.php:35,51<br>The 'items' column is cast as 'array' (JSON) AND a items() HasMany relationship is defined. Relationships take precedence, completely shadowing the JSON column data.                                              |

| ID    | Severity | Category             | Description                                                                                                                                                                                                                                                                                                   |
|-------|----------|----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BE-09 | CRITICAL | Model Bug            | <b>User trades() orWhere breaks eager loading</b><br>File: User.php:94-98<br>orWhere on a relationship definition leaks into the parent query when eager-loaded, corrupting results for ALL users. This is a well-documented Laravel anti-pattern.                                                            |
| BE-10 | CRITICAL | Model Bug            | <b>User conversations() returns wrong model type</b><br>File: User.php:110-114<br>belongsToMany(User::class, 'conversations') returns User models, NOT Conversation models. All consuming code expecting Conversation objects will break.                                                                     |
| BE-11 | CRITICAL | Security             | <b>MessageSent broadcasts on PUBLIC Channel</b><br>File: MessageSent.php:27<br>Uses public Channel, allowing any WebSocket client to subscribe without authentication and read ALL messages for any conversation. No channel authorization exists.                                                            |
| BE-12 | CRITICAL | Privilege Escalation | <b>Mass Assignment: role in User fillable</b><br>File: User.php:25<br>'role' is in \$fillable. A malicious user can inject role:'admin' in any mass-assignment request and escalate to admin.                                                                                                                 |
| BE-13 | CRITICAL | Mass Assignment      | <b>Mass Assignment: Product self-verification &amp; seller spoofing</b><br>File: StoreProductRequest.php:28,33-35<br>StoreProductRequest allows verified, rating, review_count, sold, and seller_id to be set by the user. Seller can self-verify, fake popularity, or create products under another account. |

## 1.2 High Severity (21 bugs)

| ID    | Severity | Category       | Description                                                                                                                                                                                                                                                  |
|-------|----------|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BE-14 | HIGH     | Data Integrity | <b>Order creation: no database transaction</b><br>File: OrderController.php:94-119<br>Order creation involves Order::create plus multiple OrderItem::create calls. If any OrderItem fails, the order exists without items. No DB::transaction() wrapping.    |
| BE-15 | HIGH     | Race Condition | <b>Trade creation: race condition (no transaction/lock)</b><br>File: TradeController.php:153-173<br>The check for active trades and Trade::create are not in a transaction. Concurrent requests could create two trades for the same items.                  |
| BE-16 | HIGH     | Race Condition | <b>Order number generation: race condition</b><br>File: OrderController.php:72-77<br>Order number is generated by querying last order and incrementing. Without a transaction + lock, concurrent requests can generate duplicate order numbers.              |
| BE-17 | HIGH     | Logic          | <b>TradeController rate(): can rate multiple times</b><br>File: TradeController.php:462-505<br>No check if the user already rated this trade. A user can call rate() repeatedly, corrupting the rating average and incrementing trades_count multiple times. |

| ID    | Severity | Category        | Description                                                                                                                                                                                                                                                     |
|-------|----------|-----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BE-18 | HIGH     | Logic           | <b>PromoController: used_count never incremented</b><br>File: PromoController.php:12-60<br>When a promo code is validated, used_count is never incremented. The max_uses limit is never enforced - promo codes have unlimited uses.                             |
| BE-19 | HIGH     | Token Security  | <b>LogoutController: only deletes refresh token</b><br>File: LogoutController.php:47-48<br>Only the refresh token is deleted on logout. The access token remains valid for 15 minutes, allowing continued API access after logout.                              |
| BE-20 | HIGH     | Logic           | <b>User collection() relationship is misleading</b><br>File: User.php:69-73<br>collection() returns Products where trade_available=true, NOT Collection models. loadCount(['collection']) produces incorrect collection_count in auth responses.                |
| BE-21 | HIGH     | Logic           | <b>AdminProductController: tradeCount uses wrong IDs</b><br>File: AdminProductController.php:74-76<br>Queries trades by product ID, but trades reference collection IDs. Will always return 0 or wrong results.                                                 |
| BE-22 | HIGH     | Logic           | <b>SellerController: revenue sums entire order total</b><br>File: SellerController.php:22-24<br>Revenue calculated as sum of order total, but orders may contain products from multiple sellers. Should only include this seller's line items.                  |
| BE-23 | HIGH     | Security        | <b>Export methods lose authentication</b><br>File: TransactionController.php:283+<br>new Request(array_merge(...)) creates a Request with no authenticated user. When index() calls request->user(), it returns null, causing NPE or returning all users' data. |
| BE-24 | HIGH     | Mass Assignment | <b>Mass Assignment: seller stats in User fillable</b><br>File: User.php:27<br>rating, positive_rate, trades_count, total_sales, is_verified_seller are all mass-assignable. A user can inflate their own rating/sales or self-verify as seller.                 |
| BE-25 | HIGH     | Mass Assignment | <b>Mass Assignment: verified in Product fillable</b><br>File: Product.php:23<br>'verified' is in \$fillable. Any seller can mark their own product as verified via mass assignment.                                                                             |
| BE-26 | HIGH     | Mass Assignment | <b>Mass Assignment: payment_status in Order fillable</b><br>File: Order.php:26<br>A user could mark their own order as 'Paid' without actually paying.                                                                                                          |
| BE-27 | HIGH     | Mass Assignment | <b>Mass Assignment: used_count in PromoCode fillable</b><br>File: PromoCode.php:15<br>Can be manipulated to bypass max_uses limits.                                                                                                                             |
| BE-28 | HIGH     | Missing Cast    | <b>User is_banned missing from fillable and casts</b><br>File: User.php:24-28<br>Migration adds is_banned boolean but User model has no cast for it. Without a boolean cast, attribute may return 0/1 instead of true/false.                                    |
| BE-29 | HIGH     | Missing Cast    | <b>Message attachment JSON missing cast</b><br>File: Message.php:23-25<br>Migration defines attachment as json->nullable() but model has no cast. Accessing message->attachment returns raw JSON string instead of decoded array.                               |

| ID    | Severity | Category       | Description                                                                                                                                                                                                                                                                                                |
|-------|----------|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BE-30 | HIGH     | Schema         | <b>Soft Delete + cascadeOnDelete inconsistency (5 tables)</b><br>File: Migrations: order_items, wishlists, etc.<br>These tables have product_id with cascadeOnDelete referencing products, but Product uses SoftDeletes. Cascade only fires on hard delete, not soft delete, creating orphaned references. |
| BE-31 | HIGH     | Race Condition | <b>Product SKU generation race condition</b><br>File: Product.php:47-53<br>The creating event finds the latest product and increments SKU number without any database lock. Concurrent requests can generate the same SKU.                                                                                 |
| BE-32 | HIGH     | Business Logic | <b>Trade canComplete() contradicts state machine</b><br>File: Trade.php:118-121<br>canComplete() checks status==='agreed' && bothShipped(), but allowedTransitions says 'completed' can only be reached from shipped_initiator or shipped_receiver - NOT from 'agreed'.                                    |
| BE-33 | HIGH     | Code Bug       | <b>RefreshController has broken PHP code</b><br>File: RefreshController.php:48-102<br>The RefreshController has completely broken control flow from line 48 onward - incorrect syntax mixing bare arrays and variable assignments without response()->json(). Token refresh flow is broken.                |
| BE-34 | HIGH     | Security       | <b>No rate limiting on any endpoint</b><br>File: routes/api.php<br>No throttle/rate-limiting middleware anywhere. Attackers can brute-force login, registration, token refresh, and spam any API endpoint.                                                                                                 |

## 1.3 Medium Severity (20 bugs)

| ID    | Severity | Category         | Description                                                                                                                                                                                                                                                                      |
|-------|----------|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BE-35 | MEDIUM   | State Management | <b>TradeController ship(): bypasses state machine</b><br>File: TradeController.php:338-349<br>Uses trade->update(['status'=>'shipped_initiator']) instead of transitionTo(), bypassing the state machine. Future side effects in transitionTo() would be missed.                 |
| BE-36 | MEDIUM   | State Management | <b>TradeController confirmReceived(): incomplete logic</b><br>File: TradeController.php:366-402<br>Auto-completes trade if bothShipped(), but 'confirm received' != 'shipped'. No record of who confirmed receipt. If only one party confirms, trade auto-completes incorrectly. |
| BE-37 | MEDIUM   | Logic            | <b>CommunityController like(): no duplicate check</b><br>File: CommunityController.php:126-130<br>like() simply increments the count on every call. A user can like the same post unlimited times, inflating the count.                                                          |
| BE-38 | MEDIUM   | Database         | <b>CollectionController: name-asc sort doesn't work</b><br>File: CollectionController.php:36-37<br>orderBy inside whereHas has no effect. whereHas only adds EXISTS subquery, it doesn't apply ordering.                                                                         |
| BE-39 | MEDIUM   | Logic            | <b>TransactionController: orders not filtered by type</b><br>File: TransactionController.php:22-64<br>The type query parameter (buy/sell/trade/all) only filters trades. Orders are always included regardless of the type value.                                                |

| ID    | Severity | Category         | Description                                                                                                                                                                                                                                                           |
|-------|----------|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BE-40 | MEDIUM   | Logic            | <b>DashboardController: totalRevenue includes all orders</b><br>File: DashboardController.php:21<br>Order::sum('total') sums ALL orders including unpaid, cancelled, and refunded. Should filter where payment_status='Paid'.                                         |
| BE-41 | MEDIUM   | Logic            | <b>AdminAnalyticsController: month filter missing year</b><br>File: AdminAnalyticsController.php:39-42<br>whereMonth('created_at', now->month) only filters by month number, not year. Users active in same month of any year are counted.                            |
| BE-42 | MEDIUM   | Performance      | <b>ConversationController: N+1 queries in index()</b><br>File: ConversationController.php:31-34<br>For each conversation, a separate query counts unread messages. Classic N+1 problem.                                                                               |
| BE-43 | MEDIUM   | Security         | <b>LoginController: empty email/phone produces unintended matches</b><br>File: LoginController.php:19-26<br>If both email and phone are present but empty strings, the where closure builds WHERE email="" OR phone="", potentially matching users with empty fields. |
| BE-44 | MEDIUM   | Data Integrity   | <b>OrderController: double data storage for items</b><br>File: OrderController.php:94-119<br>Items stored both in JSON column of orders table AND as separate OrderItem records. Creates data duplication and potential inconsistency.                                |
| BE-45 | MEDIUM   | Validation       | <b>UpdateProfileRequest: avatar validation conflicts</b><br>File: UpdateProfileRequest.php:24<br>Avatar validated as 'url' but MeController checks hasFile('avatar'). An UploadedFile object would fail the url validation rule.                                      |
| BE-46 | MEDIUM   | Database         | <b>WishlistController: join causes ambiguous columns</b><br>File: WishlistController.php:25-40<br>The join for sorting causes ambiguous column names and may break eager-loaded relationships. select() is not called.                                                |
| BE-47 | MEDIUM   | Logic            | <b>ProductController: featured() ignores limit parameter</b><br>File: ProductController.php:103-136<br>Only trending uses the limit variable. newArrivals is hardcoded to 8, rareFinds to 6, recommendations to 8.                                                    |
| BE-48 | MEDIUM   | Logic            | <b>ProductController: flash deal deadline is always sliding</b><br>File: ProductController.php:155<br>dealDeadline = now()->addHours(12) recalculates on every request. Deadline never actually reaches.                                                              |
| BE-49 | MEDIUM   | Security         | <b>Public order tracking leaks PII</b><br>File: OrderController.php:247-269<br>The tracking() method is public and returns shippingAddress. Anyone who guesses an order number can see shipping addresses.                                                            |
| BE-50 | MEDIUM   | Race Condition   | <b>ConversationController: firstOrCreate race condition</b><br>File: ConversationController.php:75-78<br>Not wrapped in a transaction. Two concurrent requests between same users could create duplicate conversations.                                               |
| BE-51 | MEDIUM   | State Management | <b>AdminTradeController: no transaction on forceComplete/forceCancel</b><br>File: AdminTradeController.php:162-197<br>transitionTo() and increment('trades_count') are separate operations. If increment fails, trade is transitioned but stats are wrong.            |

| ID    | Severity | Category    | Description                                                                                                                                                                                                                                           |
|-------|----------|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BE-52 | MEDIUM   | Performance | <b>ProductController priceDrops(): N+1 query</b><br>File: ProductController.php:192-210<br>Each product triggers a separate priceHistory() query. Classic N+1 problem.                                                                                |
| BE-53 | MEDIUM   | Performance | <b>User getStatsAttribute() N+1 query problem</b><br>File: User.php:117-125<br>The accessor executes 4 separate COUNT queries every time user->stats is accessed. Creates N+1 when looping users.                                                     |
| BE-54 | MEDIUM   | Security    | <b>No current password verification on password change</b><br>File: MeController.php:45<br>When changing password, no verification that user knows current password. An attacker with active session can change password without knowing the old one. |

## 1.4 Low Severity (11 bugs)

| ID    | Severity | Category   | Description                                                                                                                                                                                                                                    |
|-------|----------|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BE-55 | LOW      | Hardcoded  | <b>GeoController: hardcoded province/city data</b><br>File: GeoController.php:12-43<br>All geographic data is hardcoded in the controller. Only 10 provinces with limited cities.                                                              |
| BE-56 | LOW      | Hardcoded  | <b>OrderController: hardcoded shipping costs</b><br>File: OrderController.php:63-67<br>Shipping costs (20000, 45000, 80000) are hardcoded in a match expression.                                                                               |
| BE-57 | LOW      | Hardcoded  | <b>OrderController: hardcoded dummy payment details</b><br>File: OrderController.php:335-381<br>Bank account number, phone, and QR code URL are hardcoded dummy values.                                                                        |
| BE-58 | LOW      | Logic      | <b>ProductController: LIKE fallback with special chars</b><br>File: ProductController.php:38-42<br>LIKE fallback doesn't escape special wildcard characters (% , _) in user input.                                                             |
| BE-59 | LOW      | Logic      | <b>CSV export: no escaping for quotes</b><br>File: Multiple controllers<br>CSV values are wrapped in quotes but internal double quotes are not escaped.                                                                                        |
| BE-60 | LOW      | Validation | <b>AdminAnalyticsController export: month format not validated</b><br>File: AdminAnalyticsController.php:194<br>explode('-', month) assumes format is always Y-m. If user sends invalid format, m is undefined.                                |
| BE-61 | LOW      | Security   | <b>AdminUserController: allows self-demotion</b><br>File: AdminUserController.php:122-131<br>An admin can set their own role to 'user', potentially locking out all admins.                                                                    |
| BE-62 | LOW      | Logic      | <b>AdminProductController: update() ignores is_hidden=false</b><br>File: AdminProductController.php:158-163<br>is_hidden is only handled when true (soft delete). If is_hidden=false is sent for a soft-deleted product, it won't be restored. |
| BE-63 | LOW      | Logic      | <b>TradeController: negotiate allows both parties to counter</b><br>File: TradeController.php:257-286<br>Either party can negotiate, which can create infinite counter-offer loops.                                                            |

| ID    | Severity | Category      | Description                                                                                                                                                                                |
|-------|----------|---------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BE-64 | LOW      | Performance   | <b>CommunityController show(): no pagination on comments</b><br>File: CommunityController.php:46<br>Loads ALL comments. Popular posts with thousands of comments cause memory/time issues. |
| BE-65 | LOW      | Inconsistency | <b>SellerResource: id cast to string</b><br>File: SellerResource.php:14<br>Casts seller ID to string while ProductResource uses integer IDs. Can cause frontend comparison bugs.           |

## 2. Frontend (Next.js/React) Bugs

The frontend analysis covers all React components, pages, Zustand store, API client/proxy libraries, hooks, and configuration files. A total of 42 bugs were identified, with 4 Critical bugs that will cause compilation failures or runtime crashes.

### 2.1 Critical Severity (4 bugs)

| ID    | Severity | Category      | Description                                                                                                                                                                                                                                                        |
|-------|----------|---------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FE-01 | CRITICAL | Rendering     | <b>MyCollectionPage.tsx: completely broken JSX</b><br>File: MyCollectionPage.tsx:236-271<br>The JSX return is completely corrupted - tag names, attributes, and text mixed across wrong elements. This page will not render at all and causes a compilation error. |
| FE-02 | CRITICAL | Runtime Crash | <b>NotificationsPage: undefined variable notificationsList</b><br>File: NotificationsPage.tsx:211<br>References notificationsList.length but the variable is notifications. Causes ReferenceError at runtime and crashes the empty state rendering.                |
| FE-03 | CRITICAL | Runtime Crash | <b>ProductCard: missing import for Package icon</b><br>File: ProductCard.tsx:49<br>Uses Package icon but it's not imported from lucide-react. Runtime crash when any product image fails to load.                                                                  |
| FE-04 | CRITICAL | Runtime Crash | <b>ProductDetailPage: fallback to empty object causes errors</b><br>File: ProductDetailPage.tsx:35<br>selectedProduct    products.find()    products[0]    {} returns {} when no product found. Accessing product.seller.name on empty object causes TypeError.    |

### 2.2 High Severity (16 bugs)

| ID    | Severity | Category    | Description                                                                                                                                                                                                          |
|-------|----------|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FE-05 | HIGH     | React Hooks | <b>page.tsx: missing useEffect dependencies</b><br>File: page.tsx:39-41<br>useEffect uses auth.isAuthenticated and fetchMe but has empty dependency array. fetchMe won't be called with freshest function reference. |



| ID    | Severity | Category          | Description                                                                                                                                                                                                                                       |
|-------|----------|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FE-06 | HIGH     | Performance/State | <b>page.tsx: key={page} remounts all components</b><br>File: page.tsx:90<br>key={page} forces React to unmount and remount entire page on every navigation, destroying all local state and losing form inputs, scroll state, loading states.      |
| FE-07 | HIGH     | State Management  | <b>ProductCard: stale wishlist liked state</b><br>File: ProductCard.tsx:10<br>Local liked state initialized once from wishlist array but never syncs when wishlist changes externally.                                                            |
| FE-08 | HIGH     | Rendering         | <b>ProductCard: className template literal not interpolated</b><br>File: ProductCard.tsx:38<br>Template literal \${fallbackColors[...] } is inside regular string (double quotes), NOT backticks. Variable expression rendered as literal string. |
| FE-09 | HIGH     | React Hooks       | <b>ShopPage: missing products in useMemo dependency</b><br>File: ShopPage.tsx:78-85<br>products from store is used inside useMemo but not listed in dependency array. When products update from API, filteredProducts won't recalculate.          |
| FE-10 | HIGH     | React Hooks       | <b>SearchPage: missing products in useMemo dependency</b><br>File: SearchPage.tsx:73-87<br>Same as FE-09. products used but not in dependency array [query, filters, sortBy].                                                                     |
| FE-11 | HIGH     | React Hooks       | <b>WishlistPage: wrong useMemo dependency</b><br>File: WishlistPage.tsx:65<br>Memo depends on wishlist (IDs) but sorts wishlistItems (Products). When wishlistItems updates from API, memo won't recalculate.                                     |
| FE-12 | HIGH     | React Hooks       | <b>CommunityPage: missing posts in useMemo dependency</b><br>File: CommunityPage.tsx:74<br>posts used in useMemo but not in dependency array [searchQuery, activeTag].                                                                            |
| FE-13 | HIGH     | Runtime Crash     | <b>store.ts: SSR crash - localStorage at module level</b><br>File: store.ts:148-157<br>getInitialAuth() calls localStorage.getItem at module evaluation time. During SSR, localStorage is undefined and crashes the entire app.                   |
| FE-14 | HIGH     | Type Error        | <b>store.ts: toggleWishlist declared sync but is async</b><br>File: store.ts:230-243<br>Interface declares toggleWishlist: (productId: string) => void but implementation is async. Callers relying on sync completion see stale state.           |
| FE-15 | HIGH     | State Management  | <b>store.ts: toggleWishlist doesn't update wishlistItems</b><br>File: store.ts:230-243<br>After toggle, only wishlist (ID array) is updated. wishlistItems, wishlistTotal, wishlistPriceDropCount are not refreshed.                              |
| FE-16 | HIGH     | Type Error        | <b>CheckoutPage: categoryIcons type mismatch</b><br>File: CheckoutPage.tsx:28-33<br>Record used but values are Lucide icon components, not strings.                                                                                               |
| FE-17 | HIGH     | Type Error        | <b>RegisterPage: password_confirmation not in store interface</b><br>File: RegisterPage.tsx:33<br>Register passes password_confirmation but store's register function signature has no such field. API may reject the request.                    |

| ID    | Severity | Category         | Description                                                                                                                                                                                                                                                     |
|-------|----------|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FE-18 | HIGH     | Navigation       | <b>TradeOfferPage: uses window.location.search instead of store</b><br>File: TradeOfferPage.tsx:74<br>Uses window.location.search but app uses zustand store navigation. window.location.search is always empty because navigation doesn't update the real URL. |
| FE-19 | HIGH     | React Hooks      | <b>MyCollectionPage: missing fetchCollections in useEffect dep</b><br>File: MyCollectionPage.tsx:54<br>fetchCollections not in dependency array.                                                                                                                |
| FE-20 | HIGH     | State Management | <b>TransactionsPage: incorrect hasMore pagination logic</b><br>File: TransactionsPage.tsx:57<br>hasMore is always true whenever there are any transactions. Should compare loaded items count against total.                                                    |

## 2.3 Medium Severity (13 bugs)

| ID    | Severity | Category         | Description                                                                                                                                                                                              |
|-------|----------|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FE-21 | MEDIUM   | Performance      | <b>layout.tsx: external Google font via link tag</b><br>File: layout.tsx:17-22<br>Using link tag for Google Fonts blocks rendering and prevents Next.js font optimization.                               |
| FE-22 | MEDIUM   | Performance      | <b>page.tsx: entire app is 'use client'</b><br>File: page.tsx:1<br>Root page is 'use client', defeating SSR/SSG benefits - no server-rendered HTML, slower initial load, poor SEO.                       |
| FE-23 | MEDIUM   | React Hooks      | <b>Navbar: missing fetchNotifications in useEffect dep</b><br>File: Navbar.tsx:36<br>fetchNotifications not in dependency array.                                                                         |
| FE-24 | MEDIUM   | Accessibility    | <b>TradeOfferPage: uses alert() for error feedback</b><br>File: TradeOfferPage.tsx:89,103<br>Uses alert() which blocks UI thread and is inaccessible.                                                    |
| FE-25 | MEDIUM   | Form Handling    | <b>ProfilePage: Save button has no onClick handler</b><br>File: ProfilePage.tsx:109<br>Save Changes button does nothing - user profile edits are never persisted.                                        |
| FE-26 | MEDIUM   | Navigation       | <b>ProductDetailPage: Buy Now same as Add to Cart</b><br>File: ProductDetailPage.tsx:226<br>Both buttons call handleAddToCart. Buy Now should add to cart AND navigate to checkout.                      |
| FE-27 | MEDIUM   | Form Handling    | <b>CheckoutPage: no form validation before order</b><br>File: CheckoutPage.tsx:89-103<br>handlePlaceOrder called without validating required fields. Order can be submitted with empty shipping address. |
| FE-28 | MEDIUM   | State Management | <b>FilterSidebar: uses static mock products</b><br>File: FilterSidebar.tsx:5<br>Uses static mock products array for computing filter counts. When real products loaded from API, counts are wrong.       |

| ID    | Severity | Category         | Description                                                                                                                                                                                                                |
|-------|----------|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FE-29 | MEDIUM   | Memory Leak      | <b>api-client.ts: memory leak in createAbortSignal</b><br>File: api-client.ts:87-105<br>Event listener added to external AbortSignal but never removed. Leaks listeners if controller is reused.                           |
| FE-30 | MEDIUM   | Security         | <b>api.ts: CSRF token on global window object</b><br>File: api.ts:17-18<br>CSRF token stored as window.__csrfToken, accessible to any script including XSS payloads.                                                       |
| FE-31 | MEDIUM   | Type Error       | <b>store.ts: excessive any types</b><br>File: store.ts:114,121,133<br>collections: any[], trades: any[], transactions: any[] lose all type safety.                                                                         |
| FE-32 | MEDIUM   | State Management | <b>OrderTrackingPage: uses cart data instead of order data</b><br>File: OrderTrackingPage.tsx:52-59<br>Calculates subtotal from cart items and uses cart.map() to display order items, but should use selectedOrder items. |
| FE-33 | MEDIUM   | Rendering        | <b>NotificationsPage: broken time grouping logic</b><br>File: NotificationsPage.tsx:42-66<br>Fragile time parsing: parseInt(time) comparisons are unreliable, 'yesterday' condition misclassifies relative dates.          |

## 2.4 Low Severity (9 bugs)

| ID    | Severity | Category      | Description                                                                                                                                                                                    |
|-------|----------|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FE-34 | LOW      | Performance   | <b>ProductDetailPage: ratingBreakdown not memoized</b><br>File: ProductDetailPage.tsx:48-54<br>Computed on every render instead of being wrapped in useMemo.                                   |
| FE-35 | LOW      | Rendering     | <b>HomePage: flash deal countdown is static</b><br>File: HomePage.tsx:88<br>Countdown is a hardcoded string with CSS pulse, not actual countdown timer.                                        |
| FE-36 | LOW      | Form Handling | <b>CartPage: promo code input has no functionality</b><br>File: CartPage.tsx:247-258<br>Promo code input and Apply button have no onChange/onClick handlers. Uncontrolled and non-functional.  |
| FE-37 | LOW      | Form Handling | <b>CommunityPage: New Discussion button has no handler</b><br>File: CommunityPage.tsx:115<br>Button has no onClick handler.                                                                    |
| FE-38 | LOW      | Navigation    | <b>CommunityPage: breadcrumb Home link empty onClick</b><br>File: CommunityPage.tsx:87<br>onClick is empty function instead of navigate('home'). Clicking does nothing.                        |
| FE-39 | LOW      | Navigation    | <b>Footer: company links are non-functional</b><br>File: Footer.tsx:39-53<br>About Us, Careers, Help Center are spans with no navigation. Look clickable but do nothing.                       |
| FE-40 | LOW      | Navigation    | <b>MobileNav: You navigates to collector-profile</b><br>File: MobileNav.tsx:11<br>The You tab navigates to collector-profile instead of profile. Users expect You to go to their own settings. |

| ID    | Severity | Category         | Description                                                                                                                                                                     |
|-------|----------|------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FE-41 | LOW      | State Management | <b>DealsPage: countdown wraps to 86399 at zero</b><br>File: DealsPage.tsx:36<br>When countdown reaches 0, wraps to 86399 (23:59:59) creating infinite loop instead of stopping. |
| FE-42 | LOW      | Resilience       | <b>No React Error Boundaries</b><br>File: All pages<br>No Error Boundaries exist. If any component throws during render, entire app crashes with white screen.                  |

## 3. Configuration & Security Bugs

Cross-cutting security and configuration issues spanning both frontend and backend, including CORS misconfiguration, exposed secrets, insecure defaults, and missing production safeguards.

### 3.1 All Configuration & Security Bugs (17)

| ID     | Severity | Category              | Description                                                                                                                                                                                                 |
|--------|----------|-----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CFG-01 | CRITICAL | proxy route.ts:11     | <b>Frontend CORS wildcard origin</b><br>File: proxy route.ts:11<br>Access-Control-Allow-Origin: * allows any origin to make cross-origin requests, completely bypassing backend CORS restrictions.          |
| CFG-02 | CRITICAL | FE .env.example:9     | <b>Encryption key exposed to client-side</b><br>File: FE .env.example:9<br>NEXT_PUBLIC_ENCRYPTION_KEY is embedded in client JS bundle. AES-GCM encryption key readable by anyone inspecting browser source. |
| CFG-03 | HIGH     | FE .env.local:3       | <b>All-zero encryption key</b><br>File: FE .env.local:3<br>Encryption key is all zeros, providing zero cryptographic security.                                                                              |
| CFG-04 | HIGH     | BE .env.example:3     | <b>APP_KEY empty in .env.example</b><br>File: BE .env.example:3<br>APP_KEY is empty. Required for encryption, session security, and CSRF protection.                                                        |
| CFG-05 | HIGH     | BE .env.example:75-77 | <b>Reverb WebSocket secrets in version control</b><br>File: BE .env.example:75-77<br>REVERB_APP_ID/KEY/SECRET are committed to repo with guessable values.                                                  |
| CFG-06 | HIGH     | BE .env.example:79    | <b>WebSocket over insecure HTTP</b><br>File: BE .env.example:79<br>REVERB_SCHEME=http means WebSocket traffic including chat messages transmitted in plaintext.                                             |
| CFG-07 | MEDIUM   | BE .env.example:4     | <b>Debug mode true in .env.example</b><br>File: BE .env.example:4<br>APP_DEBUG=true as default exposes detailed error messages with stack traces in production.                                             |

| ID     | Severity | Category                                | Description                                                                                                                                                                                                       |
|--------|----------|-----------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CFG-08 | MEDIUM   | next.config.ts:10-14                    | <b>Hardcoded backend URL in Next.js rewrites</b><br>File: next.config.ts:10-14<br>Rewrite destination hardcoded as localhost:8080. Won't work in any non-local environment.                                       |
| CFG-09 | MEDIUM   | next.config.ts + api-client.ts + api.ts | <b>Dual proxy path conflict</b><br>File: next.config.ts + api-client.ts + api.ts<br>Three different ways to reach backend (rewrites, /api/proxy, /api direct) create confusion and potential double-proxy issues. |
| CFG-10 | MEDIUM   | next.config.ts:28                       | <b>TypeScript build errors ignored</b><br>File: next.config.ts:28<br>ignoreBuildErrors: true masks runtime bugs and type-safety issues during production builds.                                                  |
| CFG-11 | MEDIUM   | next.config.ts:30                       | <b>React Strict Mode disabled</b><br>File: next.config.ts:30<br>reactStrictMode: false hides potential unsafe lifecycles and deprecated API usage.                                                                |
| CFG-12 | MEDIUM   | tsconfig.json:13                        | <b>noImplicitAny disabled</b><br>File: tsconfig.json:13<br>Allows implicit any type, reducing type safety and increasing runtime error risk.                                                                      |
| CFG-13 | MEDIUM   | BE .env.example:32                      | <b>Session encryption disabled</b><br>File: BE .env.example:32<br>SESSION_ENCRYPT=false. If database compromised, session data is readable.                                                                       |
| CFG-14 | MEDIUM   | BE session.php:172                      | <b>Session secure cookie not set</b><br>File: BE session.php:172<br>In production, session cookies sent over HTTP, allowing session hijacking.                                                                    |
| CFG-15 | HIGH     | Multiple BE controllers                 | <b>CSV injection in export endpoints</b><br>File: Multiple BE controllers<br>CSV export allows formula injection payloads (=CMD, +CMD, -CMD) that execute when CSV opened in spreadsheet apps.                    |
| CFG-16 | LOW      | FE store.ts:168,174                     | <b>Token stored in localStorage (XSS vulnerable)</b><br>File: FE store.ts:168,174<br>Auth tokens in localStorage accessible to any JavaScript. If XSS exists, tokens can be stolen.                               |
| CFG-17 | LOW      | BE database.php:20                      | <b>Default database is SQLite</b><br>File: BE database.php:20<br>SQLite unsuitable for production e-commerce with concurrent users.                                                                               |

## 4. Top Priority Action Items

The following items represent the highest-impact fixes that should be addressed immediately before any production deployment. Each item is ranked by risk severity and potential blast radius.

| # | Priority | Action                                              | File(s)        | Rationale                                                                                                             |
|---|----------|-----------------------------------------------------|----------------|-----------------------------------------------------------------------------------------------------------------------|
| 1 | CRITICAL | Move AdminController routes behind admin middleware | routes/api.php | Three admin endpoints are accessible to any authenticated user. This is a single route-file fix that takes 2 minutes. |

| #  | Priority | Action                                                                       | File(s)                           | Rationale                                                                                                                                                    |
|----|----------|------------------------------------------------------------------------------|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2  | CRITICAL | Add ownership checks to Order, Product, TradeIn, Shipping controllers        | Multiple controllers              | IDOR vulnerabilities allow any user to view, modify, or pay for any other user's resources. Add user_id/seller_id verification before every action.          |
| 3  | CRITICAL | Remove role from User \$fillable + restrict Product request fields           | User.php, StoreProductRequest.php | Mass assignment allows privilege escalation to admin and product self-verification/fake stats. Remove sensitive fields from fillable and request validation. |
| 4  | CRITICAL | Fix frontend CORS wildcard origin                                            | proxy route.ts                    | Access-Control-Allow-Origin: * allows any website to make API requests. Replace with specific frontend origin.                                               |
| 5  | CRITICAL | Move encryption key out of NEXT_PUBLIC_ scope                                | .env files                        | The AES-GCM key is embedded in client-side JavaScript. Encryption is useless if the key is public.                                                           |
| 6  | CRITICAL | Fix broken JSX in MyCollectionPage + undefined variable in NotificationsPage | FE pages                          | These cause compilation errors and runtime crashes. The entire MyCollection form section must be rewritten.                                                  |
| 7  | HIGH     | Add stock check + decrement + DB::transaction on order creation              | OrderController.php               | Products can be oversold to negative stock. Wrap order creation in a transaction with stock verification.                                                    |
| 8  | HIGH     | Fix broken RefreshController PHP code                                        | RefreshController.php             | Token refresh flow is completely broken due to incorrect PHP syntax. Users cannot refresh their sessions.                                                    |
| 9  | HIGH     | Add rate limiting to auth endpoints                                          | routes/api.php                    | No throttle middleware anywhere. Login, registration, and token refresh are vulnerable to brute-force attacks.                                               |
| 10 | HIGH     | Fix User model broken relationships (trades, conversations, collection)      | User.php                          | Three critical model relationship bugs corrupt query results, return wrong model types, and produce incorrect counts.                                        |